

Prototype to Production

Giulio Valentino Dalla Riva · SDD - SPC · 10 June 2026

Executive summary

SDMX Surfer's invite-only alpha is wrapping up with roughly 50 users across Pacific governments and partner organisations, and positive feedback. This document proposes the path to a public service: a time-boxed public beta in Q3 2026 on the current infrastructure, followed by a public launch in Q4 under a tiered access model with usage caps. The remaining technical work is modest and well understood: public sign-in providers plus institutional SSO, per-tier usage caps, model-drift monitoring, interface alignment with SPC conventions, and the operational basics of a public service (error tracking, dashboards, an uptime probe, a runbook, an on-call contact). What gates the timeline is a short list of governance decisions only management can make: who owns the product, which budget line carries the costs, where the service lives, and how published dashboards are moderated. Section 8 consolidates these into beta blockers, needing answers by early Q3, and launch blockers, needed by late Q3; everything else can be resolved during or after launch. Each section below closes with the open questions it depends on; they are written so that a decision can be made by reading that section alone.

1. Where We Are Today

The alpha is closing. Roughly 50 users across Pacific governments and partner organizations have used the tool, with positive feedback. The application that runs production already has:

- Invite-only authentication with magic links and password fallback
- Per-user session persistence with undo/redo and soft delete
- Public dashboard publication and a public gallery
- Per-request usage logging with token counts and authoritative cost via the AI Gateway
- BYOK support so power users can attach their own API keys
- An admin surface for invite management, audit logs, usage overview, and published-dashboard moderation
- A dependency security audit refreshed on 2026-06-08 in `SECURITY_AUDIT.md`. Zero high-severity advisories. Eleven moderate items remain, each individually classified: every one is either dev-tooling (drizzle-kit's bundled esbuild), build-time (next's nested postcss), or part of the planned `next-auth 4 → 5` migration backlog (nodemailer and uuid chains). None has a production runtime exposure path. The audit narrowed from 16 to 11 advisories via patch bumps to `resend`, `next`, `next-auth`, and one autofix.

The recurring operational pain point is global SDMX endpoint instability, which is outside our control and which we already mitigate partially through retries and structure caching.

Sources of truth this document builds on: `docs/current-architecture.md`, `SECURITY_AUDIT.md`, `dashboard-architecture.md`.

2. Timeline

Phase	Window	Definition
Alpha (current)	through 2026-Q2	Invite-only, ~50 testers, no SLA
Public beta	2026-Q3	Open access, time-boxed (1–2 months), explicit shutdown date communicated up front, capped usage
Public launch	2026-Q4	Open access with the tiered model defined in §6, committed SLA, ongoing operation

The beta is deliberately a circuit breaker: it gives us load and feedback at real scale, with an end date that lets us regroup, raise concerns, or cancel without a public retraction.

3. Strategy at a Glance

The plan, stated as plainly as possible:

1. Keep the current stack (Vercel + Railway + Neon + Resend) for beta. The migration risk is not worth taking before we have load data.
2. Add two authentication providers (GitHub, Google) before beta so people do not have to wait for invite emails.
3. Wire up usage caps tied to user tier (open-tier vs VIP), defined in §6.
4. Stand up model-drift monitoring so we can react to model deprecations and quality regressions calmly rather than urgently.
5. Bring the UI into alignment with SPC and Pacific Data Hub conventions before public launch.
6. Decide governance (§7) in parallel with the technical work, because governance choices change the timeline.

If management cannot resolve §8 by early Q3, we should still ship beta on the current setup and treat governance as a launch blocker rather than a beta blocker.

4. Technical Track

4.1 Deployment

We have two realistic options for the beta-to-launch path. We are not deciding today which one we operate for the long term.

Option A: keep the current infrastructure.

What we do:

- Point a production domain at the existing Vercel deployment.

- Change the Resend sender domain to the production address.
- Verify environment variable hygiene in Vercel and Railway.
- Add an internal status page that surfaces per-endpoint SDMX health.

What we get: launch in weeks, not months. Vercel handles TLS, autoscaling, previews. Railway handles the gateway. Neon handles Postgres backups. Predictable behaviour, with vendor support if something fails.

What we pay: variable costs that scale with usage, vendor coupling, a small but real risk that the AI SDK / Vercel function surface changes under us.

Option B: self-hosted on a single VPS (Vultr or similar).

What we do:

- Provision a single Linux box in Sydney (closest Vultr region to the Pacific).
- Run both services behind Caddy (auto-TLS), managed either with systemd or a self-hosted PaaS (Coolify or Dokploy) that gives us per-PR previews and a git-push deploy flow.
- Keep Neon for Postgres (no migration needed), or move to same-box Postgres if we want full operational control.
- Stand up our own log shipping, monitoring, backups, and on-call.

What we get: flat predictable bill (~USD 50–100 per month for the box), no vendor coupling, single mental model, single network hop between agent and gateway.

What we pay: we become our own platform team. The work to reach feature parity with Vercel previews and observability is roughly five to eight focused days, plus ongoing operational time.

Recommendation. Stay on the current setup through beta. Revisit Option B before public launch if any of the following is true: monthly bill exceeds a threshold management is uncomfortable with; vendor lock-in becomes a governance issue (for example, hosting must be on SPC-owned infrastructure); we have a person on staff comfortable owning a Linux box.

Open questions

1. Does SPC governance permit running on Vercel and Railway for a public service, or is there a requirement for hosting in a specific jurisdiction or on owned infrastructure?
2. Is there an SPC-managed domain we should use, or do we register a fresh one?
3. What is the acceptable monthly running cost during beta, and during launch?

4.2 Secrets and security posture

What we have today:

- Secrets live in `.env.local` for development and in Vercel/Railway environment variables for deployment.
- BYOK keys for end users are stored encrypted at rest in the database (`user_api_keys.encrypted_key`), decrypted only inside the model router for the duration of a request.
- An audit log (`auth_events`) records security-relevant actions.
- Magic-link callback URLs are stored server-side (`auth_magic_link_refs`) to defeat Outlook SafeLinks rewrites.
- LLM traffic is funnelled through the Vercel AI Gateway (`AI_GATEWAY_API_KEY` with `USE_AI_GATEWAY=1`). One platform key pays for every supported provider and gives us

authoritative per-request cost via `usage_logs.cost_usd`. A legacy `ANTHROPIC_API_KEY` direct-SDK path is retained behind the feature flag as rollback safety; we should retire it once we are confident in the gateway.

What is missing before public launch:

- Rotation policy and procedure for the small set of platform secrets we actually hold: `AI_GATEWAY_API_KEY` (primary), the legacy `ANTHROPIC_API_KEY` until retired, the Google API key used for embeddings (`lib/embeddings.ts`), the Resend API key, and the encryption key that protects BYOK material at rest.
- A documented secrets inventory: which keys exist, where they live, who can read them, who knows they exist.
- A `next-auth 4 → 5` migration plan to remove the legacy `nodemailer` flows tracked in the security audit. This single piece of work closes the largest residual cluster of moderate-severity advisories.
- A standing process for the dependency audit so it does not drift again. Recommended: monthly `npm audit` with an alert if the high count is non-zero, and a quarterly residual-classification review like the one in `SECURITY_AUDIT.md`.
- An incident-response page (see §5).

This work is small in volume but it is the kind of thing that becomes urgent only after it has already failed.

Open questions

1. Who in SPC is the formal owner of these secrets, and who is authorised to rotate them?
2. Is there an SPC password manager or secret vault we should use, or do we self-manage?
3. Are there specific cybersecurity certifications or audits SPC requires before a public launch?

4.3 Authentication: SSO, GitHub, Google

SPC already runs Okta and Keycloak. Both are first-class providers in NextAuth (Okta via the built-in provider, Keycloak via the Keycloak provider). This changes the shape of the work:

- For SPC staff and partner-organisation users with managed identities, SSO through Okta or Keycloak is the right primary path. Decision needed on which one is the institutional default.
- For external public users (open tier, §6), Google and GitHub are the realistic providers. Google covers most users; GitHub covers the developer-leaning subset.
- Magic-link sign-in stays as a fallback for users who have neither.

The database schema already includes the OAuth accounts table (`auth_accounts`). Wiring up:

- App registrations with the chosen Okta/Keycloak instance, plus Google and GitHub.
- Two callback URLs per provider (beta and production).
- A decision on how external (OAuth) identities interact with the invite allowlist (§6).
- A linking story: a user who first signs in with Google and is later promoted to staff via Okta should not become two accounts.
- UI work on `/login` to show provider buttons in a sensible order (SSO first, social providers second, magic link last).

Effort: two to four days, depending on how much of the linking logic we want from day one.

Open questions

1. Is Okta or Keycloak the canonical SPC identity provider for this product? If both, which takes precedence in the UI?
2. Who at SPC owns the Okta/Keycloak app registration and approves the callback URLs and scopes?
3. For the open public tier (§6), do we accept Google and GitHub, or only one?
4. Do we restrict any email domains (block free email, allow only .gov and named partner domains, etc.) in the open tier?

4.4 Model drift monitoring

Models change. Names get deprecated, pricing shifts, quality regresses. We need a small set of regression tests we run on a schedule that exercises the agent end-to-end against representative SDMX requests, asserts that the produced configs are valid and visually plausible, and records the cost and latency.

What this looks like in practice:

- A `tests/golden/` directory with ~15 canonical user prompts, each paired with assertions on the produced config shape.
- A scheduled job (GitHub Actions weekly, or Vercel Cron) that runs the suite against the currently configured model and writes results to the existing `usage_logs` table with a synthetic user id.
- An admin view that plots success rate, cost per prompt, and latency over time per model.
- A documented procedure for switching models when a new one ships or an old one is deprecated.

Effort: two to three days for the harness, ongoing time to maintain the golden prompts.

Open questions

1. How much can we spend per week on the regression suite (it costs real money each run)?
2. Who reviews the results, and how often?
3. Do we want to evaluate Anthropic, Google, and OpenAI models in parallel, or stick with our current provider and only react when forced?

4.5 Interface alignment with SPC and Pacific Data Hub

To launch under any SPC umbrella, the interface needs to match institutional conventions. The work splits into:

- Visual identity: SPC and PDH header, footer, colour palette accents, fonts. Our existing Oceanic Data-Scapes design system is close in spirit but is not the official SPC palette.
- Accessibility: WCAG 2.1 AA at minimum. We should run an audit (axe, Lighthouse) and fix anything it surfaces. Pacific users include people on assistive tech.
- Languages: English by default. Whether we need French (for New Caledonia, French Polynesia, Wallis and Futuna) is a governance decision, not a technical one.
- Citations and provenance: when a dashboard displays SPC or partner data, the source needs to be cited per institutional conventions, including the .Stat URL and the date the data was retrieved.

- Footer requirements: links to SPC privacy policy, terms of use, contact, depending on where the app sits (§7.3).

Effort: three to five days for visual alignment and accessibility fixes, plus design review.

Open questions

1. Who owns the visual review and sign-off (PDH design? SPC communications?)?
2. Do we need French language support at launch, at all, or never?
3. Where does the privacy policy / terms of use copy come from? Existing SPC documents, or new copy?

5. Operations and Observability

This was not in the original brief but it cannot be left implicit at this scale.

For beta we need:

- Error tracking for both Next.js and the MCP gateway (Sentry or equivalent).
- A small set of dashboards: per-day active users, per-day cost, agent success rate, per-endpoint SDMX probe success.
- An external uptime probe on the chat endpoint.
- A documented runbook for the three most likely incidents: SDMX endpoint outage, LLM provider outage, runaway cost.
- A single on-call email or chat that reaches a real person within a defined window.

For launch we add:

- Alerts on cost-per-day exceeding a threshold.
- Alerts on auth event spikes (potential abuse).
- A status page visible to users.
- A defined SLA, even an informal one.

This is the work that closes the gap between “the app is running” and “we are running a service.”

6. Management Track

6.1 Access tiers

Proposed model:

Tier	Who	Cap	Verification
Open	Anyone who signs in with a supported provider	Strict (e.g. N agent turns per day, M dashboards per week)	Email verified through OAuth or magic link

Tier	Who	Cap	Verification
VIP	Users explicitly designated by SPC	Generous (effectively uncapped within reason)	Manual or invitation-based assignment
Internal	Admins	No cap, plus admin tools	Role on <code>auth_users.role</code>

The split is enforced via three mechanisms:

1. A `tier` column on `auth_users` (small migration).
2. Per-request budget checks in the chat route that read the tier and the user's current period usage.
3. Friendly UI messages when caps are hit, explaining how to request VIP access.

This avoids two failure modes: anonymous abuse drains the budget overnight, and good users get blocked because the system treats everyone the same.

Open questions

1. What are the actual numbers for the open-tier cap? Suggested starting point: 20 agent turns per day, 5 published dashboards total, with a periodic reset.
2. What is the formal process for someone to request VIP status? Email to whom? Approved by whom?
3. Do we maintain a public list of partner organisations whose members are automatically VIP, or is every assignment manual?
4. Do we allow account deletion on user request, and is there a retention policy on usage logs?

6.2 Communications and onboarding

For beta and launch:

- A short "what is this for, what is it not" landing message.
- Example prompts visible on first login.
- A feedback channel (an email address that goes somewhere staffed).
- A FAQ covering: who runs this, what data it uses, is the data official, what to do if a dashboard is wrong.

Open questions

1. Who is the public face of the service when a user has a question or complaint?
2. Where do bug reports and feature requests go, and who triages them?

7. Governance Track

These are the items only management can resolve. Listed in roughly the order they unblock other work.

7.1 Ownership

The product can sit under PDH (Pacific Data Hub) or under SDD (Statistics for Development Division), or be co-owned. The choice changes:

- Which budget line pays for hosting, LLM costs, and staff time.
- Which division responds to user complaints and press queries.
- Which division's standards (visual, editorial, statistical) govern outputs.
- Whose roadmap the product appears on.

Open questions

1. Who is the named owner (a division, plus an accountable individual)?
2. If co-owned, what is the split of responsibilities in writing?
3. Who is the backup if the named owner leaves?

7.2 Cost ownership

For reference, the variable costs to plan for are LLM API spend (the dominant line) plus hosting plus email delivery. A rough envelope for beta is in the low hundreds of USD per month; launch with active marketing could be an order of magnitude higher.

Open questions

1. Which budget line is the cost charged to?
2. What is the monthly cap, and what happens when we hit it? (Soft cap with email, hard cap with service degradation, request supplementary budget?)
3. Is there an existing SPC mechanism for partner organisations to contribute to running costs?

7.3 Where it sits

Options:

- A subpage within the Pacific Data Hub website (pacificdata.org/...).
- A subpage within SPC's main site (spc.int/...).
- A standalone product page on its own subdomain (surfer.pacificdata.org or similar).
- Embedded into SDD's existing offerings.

The choice affects branding, perceived authority, link permanence, and the institutional standards we have to meet.

Open questions

1. Which of the above is preferred?
2. What URL?
3. Who controls the DNS for that URL?

7.4 Public dashboard moderation

Users can publish dashboards. Once we are open to the public, this becomes a content moderation problem in addition to a technical one.

Proposed model:

- All published dashboards remain visible by default.
- An admin queue surfaces newly published dashboards for spot review.
- Any admin can unpublish.
- A "report this dashboard" link goes to a moderation address.
- Strikes against a user (multiple unpublishes) trigger account review.

This matches what already exists in the admin surface; only the reporting flow is new work.

Open questions

1. Who reviews published dashboards, and at what cadence?
2. What are the grounds for unpublishing? (Factual error, offensive content, off-topic, regional sensitivity?)
3. Is there an appeals process?
4. Do we want a "featured" set, curated by SPC, that gets higher placement on the gallery?

7.5 Marketing

If we do nothing, the product reaches existing partners. If we market, we reach more users, generate more value, and incur more cost and more moderation burden.

A middle path for launch: an announcement on the chosen host site, a post on SPC's social channels, presentations at one or two regional statistics gatherings, and word of mouth through the alpha cohort.

Open questions

1. Do we market, and if yes through which channels?
2. Is there a target audience size at launch and at six months?
3. Who writes the launch material?

7.6 KPIs

Pick a small set. Five is more than enough. Candidate metrics, grouped:

- **Adoption.** Weekly active users, sessions per active user.
- **Output.** Dashboards published per week, share of sessions that produce a published dashboard.
- **Value.** Time-to-first-dashboard, reuse rate (sessions that revisit existing dashboards).
- **Quality.** Agent success rate from the regression suite, user satisfaction signal (a one-question rating after publishing).
- **Cost.** Cost per published dashboard, cost per active user.

Open questions

1. Which three to five do we adopt as the official KPIs?
2. What are the targets at three, six, and twelve months?
3. Who reports them, to whom, on what cadence?

8. Decisions Blocking Beta and Launch

Consolidated from the open questions above. These are listed so we can see the full set at once.

Blocking beta (need answers by early Q3 2026):

- Production domain and Resend sender domain (§4.1, §7.3).
- Acceptable monthly running cost cap (§4.1, §7.2).
- Open-tier cap numbers (§6.1).
- Named owner and on-call (§5, §7.1).

Blocking launch (need answers by late Q3 2026):

- Authentication providers and any domain restrictions (§4.3).
- Visual alignment and accessibility sign-off (§4.5).
- Public dashboard moderation process (§7.4).
- KPIs and reporting cadence (§7.6).
- Hosting jurisdiction and compliance requirements (§4.1).
- Where the service sits and under whose URL (§7.3).

Everything else can be resolved during or after launch.

9. Risks

Stated plainly:

1. **SDMX endpoint instability.** Outside our control. We mitigate but cannot eliminate. Communicate honestly to users.
2. **Cost overruns.** Soft and hard caps in place, but a single viral moment could spike spend faster than we react.
3. **Content liability.** Published dashboards that misrepresent data, even unintentionally, could be attributed to SPC. Moderation matters.
4. **Model deprecations.** Providers retire models with weeks of notice. The regression suite buys us time but not infinity.
5. **Dependency on a small team.** If one person leaves, the operational story collapses. The runbook and the named owner are mitigations.
6. **Regional sensitivities.** A dashboard that treats one PICT differently from another, even algorithmically, is a reputational risk. Our existing regional-neutrality discipline applies, but we should review the published gallery periodically.

10. Next Concrete Steps

If management agrees with the shape of this document, the immediate work is:

1. Schedule a governance meeting to resolve the beta blockers in §8.
2. Begin §4.3 (OAuth providers) and §4.4 (model drift monitoring) in parallel; both are independent of governance.
3. Draft the runbook (§5) so that whoever is named on-call has something to work from.
4. Prepare the open-tier cap migration so it can ship on day one of beta.
5. Communicate the beta shutdown date publicly at the start of beta, so it is never a surprise.

This document is intended to be edited as conversations happen. When a section's open questions are answered, replace the question with the decision and the date it was made.